



2. Hafta

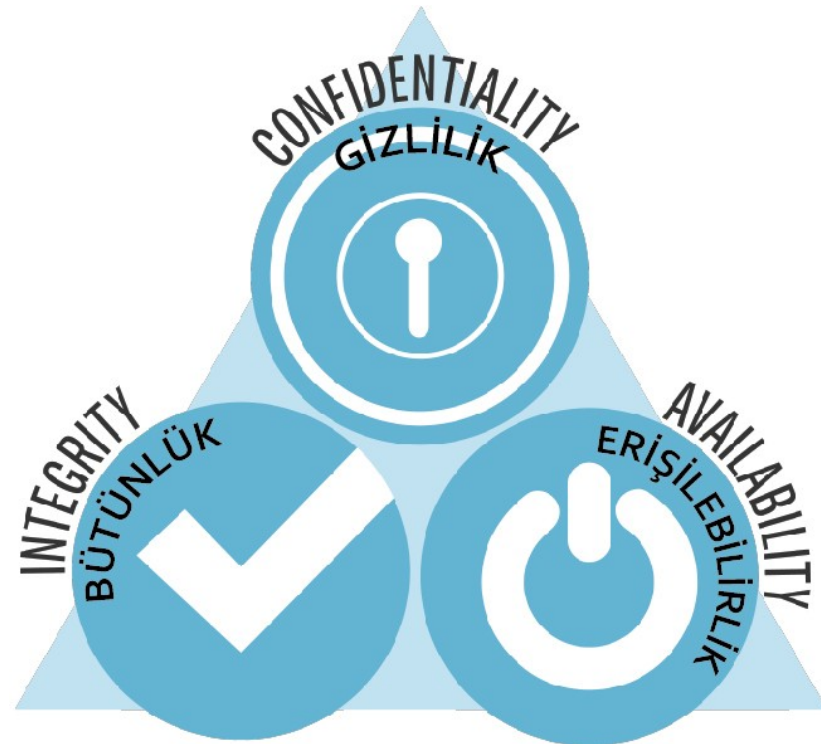
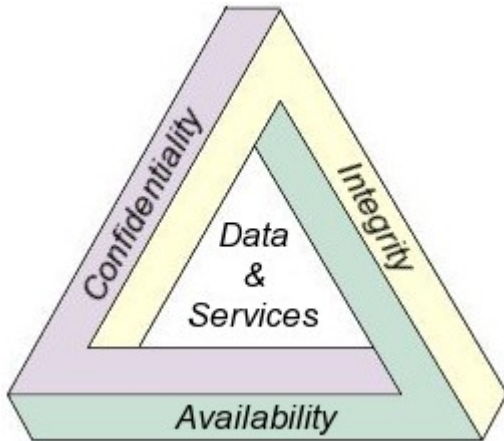
BİLGİ GÜVENLİĞİ NEDİR?
SİBER GÜVENLİK NEDİR? NASIL?
HACKER KİMDİR? HACKİNG NEDİR?

Bilgi Güvenliği

- **Bilgi:** Bir kurumun kuruluşun veya organizasyonun faaliyetlerini yürütmekte kullandıkları verilerin anlam kazanmış haline denir.
- **Bilgi Güvenliği:** Öneme sahip bilginin korunması, bütünlüğünün sağlanması, erişebilir ve ulaşabilir olmasının sağlanması için alınan gerekli, önemler ve tedbirlerdir.
- Bilgi Güvenliği Yönetim Sistemi Standardı (ISO 27001)

CIA Üçlüsü (CIA Triad)

- Confidentiality - Gizlilik
- Integrity - Bütünlük
- Availability - Erişilebilirlik
(Kullanılabilirlik)



Bilgi Güvenliği

- **Gizlilik:** Bilgilerin yetkisiz erişime karşı korunması
- **Bütünlük:** Bilgilerin eksiksiz, tam, tutarlı ve doğru olması
- **Erişilebilirlik:** Bilgilere yetkililerce ihtiyaç duyulduğunda erişilebilir olması

Bilgi Güvenliği



- **Gizlilik - Confidentiality**
Herşeyi herkesten gizlemek değil, veriye/bilgiye sadece yetkisi onların ulaşılabilmesini sağlamak. Şifreleme gibi..
- **Bütünlük - Integrity**
Yetkisiz ve izinsiz değişikliklerin engellenmesi, verinin amacına uygun derecede doğru olması.
- **Erişilebilirlik - Availability**
Veriyi iletmek, depolamak ve işlemekten sorumlu hizmetlerin devamlılığının sağlanması.
- Bilgi güvenliğinin sağlanmasından **herkes sorumludur**.
(Bilginin sahibi, kullanan, sistemi yöneten, vb..)

Yetki **paylaşılır**, sorumluluk **paylaşılmaz**. Bilgi ise **paylaşıldıkça** artar.

Bilgi Güvenliği Kategorileri

- **Ağ güvenliği** (Network security)
- **Uç/Son nokta** veya **Kullanıcı güvenliği** (Endpoint security)
- **Veri güvenliği** (Data security)
- **Uygulama güvenliği** (Application security)
- **Kimlik ve Erişim Yönetimi** (Identity and access management)
- **Güvenlik yönetimi** (Security management)
- **Sanallaştırma ve bulut** (Virtualization and cloud)

Bilgi Gvencesi

- Information Assurance, IA

Bilgi sistemlerinin ;

- Kullanılabilirliğini,
- Btnlgn,
- Doęrulanmasını,
- Gizliliğini ve
- İnkâr edememe

zelliklerini sağlar. Bilgi gvenliğini de iine alır.



Siber Güvenlik

- Siber uzayda organizasyon ve kullanıcıların varlıklarını korumak amacıyla kullanılan araçlar, politikalar, güvenlik kavram ve önlemleri, kurallar, risk yönetimi yaklaşımları, eylemler, eğitimler, uygulamalar ve teknolojilerin bütünüdür.

Kaynak: Uluslararası Telekomünikasyon Birliği (ITU)

Siber Güvenlik (Cyber Security)

- Kurum, kuruluş ve kullanıcıların varlıkları, bilgi işlem donanımlarını, personeli, altyapıları, uygulamaları, hizmetleri, telekomünikasyon sistemlerini ve siber ortamda iletilen ve/veya saklanan bilgilerin tümünü kapsamaktadır.
- Siber güvenlik, kurum, kuruluş ve kullanıcıların varlıklarına ait güvenlik özelliklerinin siber ortamda bulunan güvenlik risklerine karşı koyabilecek şekilde oluşturulmasını ve idame edilmesini sağlamayı amaçlamaktadır.

Hack

- Kırmak,
- Küçük parçalar koparmak,
- Açık yönlerini ortaya çıkarmak,
- Açıklığı kullanmak.

Anlamlarında kullanılır.

Hacking

- Sistem veya programın açığından yararlanıp erişim sağlamak, değiştirmek veya silmek.
- Açıklığı kullanma işlemidir.



Hacker

- Siber korsan,
- İnternet ve ağ alt yapısı bilgisine sahip,
- Programlama dili bilen,
- Ağ veya sisteme sızmayı başarabilen,
- Verilere-bilgilere ulaşabilen,
- Tüm işlemleri fark edilmeden yapabilen,
- İleri düzey bilgiye sahip kişidir.

Hacker

- Sistemlere sızabilme yeteneğine sahip, programlama bilgisi üst düzeyde olan ağ ve sistemlerin işleyişini iyi bilen, gerektiğinde sosyal mühendislik yapabilen, hacking araçlarını tanıyan ve bunları gerektiği zaman geliştirebilen kişilerdir.

Siber Korsanlar

- Etik, kültür, etnik veya siyasi özelliklerine göre farklılar göstermektedir.
- Siyah Şapkalı Hacker,
- Gri Şapkalı Hacker,
- Beyaz Şapkalı Hacker,
- Haktivist,
- Cracker,
- Phreaker,
- Lamer,
- Script Kiddie



Hackerlar ve Şapkaları

- Amaç ve faaliyetlerine göre;
- Siyah Şapkalı, Gri Şapkalı ve Beyaz Şapkalı



Siyah Şapkalı Hacker

- Kötü amaçlı, zarar vermek veya para odaklı,
- Sistemleri ele geçirmek veya yok etmek için,
- Saldırı gerçekleştiren, tehlikeli bilgisayar korsanıdır.
- Sisteme erişimi engelleme, bilgi değiştirme, gizli bilgi çalma gibi faaliyetlerde bulunurlar.



Beyaz Şapkalı Hacker

- Etik hacker,
- Aynı bilgi ve beceriye sahip, İyi niyetli,
- Açıklığı tespit eden, uyarar veya önleyen,
- Sistem güvenliğıinden sorumlu personel,
- Ahlaklı siber korsandır.



Gri Şapkalı Hacker

- Sistemlere sızma ve giriş yapan,
- Kötü amaç olmayıp, merak için,
- Yasallık sınırlarında saldırganlık faaliyeti olan,
- Zaman zaman tehlikeli faaliyetler içerisinde,
- Yaptıkları hukuk karşısında suç teşkil eden,
(Sisteme sızma, girme vb.) Siber korsanlardır.



Cracker

- Bilgisayar programlarının kopya korumalarını kırarak, bu programların izinsiz olarak dağıtımına imkan veren veya bu yolda çıkar sağlayan kişilere denir. (Yazılım korsanı)
- Lisansların iptali veya serial-key temini,



Hacktivistler

- Hacker + Aktivist = Hacktivist
- Kendilerine göre, toplumsal sorun veya yanlış politik durum olarak gördükleri konulara dikkat çekmek için sistemlere saldıran kişi veya gruplardır. (sanal protestocu)
 - Wikileaks,
 - Anonymous,
 - RedHack,
 - Cyber-Warrior,
 - Ayyıldız Tim,
 - SEA vb.



Lamer

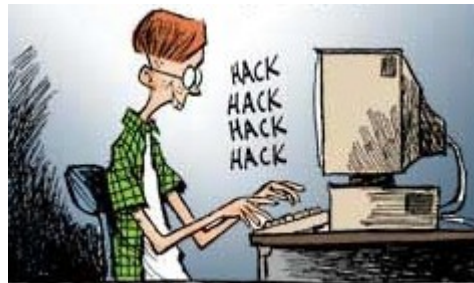
- Başkalarının önceden yazdığı betik(script) kodları veya programları çalıştırır, övünür,
- Ağ, sistem, yazılım, programlama gibi konularda bir bilgiye sahip olmadan,
- Atak yapmaya çalışan kişilerdir.

(Lamer: Özenti, basit)



Script Kiddie

- Yeterli bilgisi olmadan hazır araçlarla saldırı düzenleyen (genelde genç yaşta-çocuk) kişilere verilen isimdir. (Betikçiler-BetikKerataları)
- Tıpkı lamer'lar gibi ama bir miktar bilgi sahibi,
- Kötü niyetli, zarar verme amaçlı,
- Teknik detay ve programın nasıl çalıştığını bilmez, ama kullanımını bilenlerdir.



Phreaker

- Telefon iletişim hatlarına erişip,
- Uzun süreli Ücretsiz görüşme, vb. amaçlı,
- Telefon kırıcılarıdır.



NewBie

- Çaylak, okula yeni başlayan,
- Bilişimde veya programla da yenilere denilir,
- Betik keratolarından bir basamak üstte,
- Kendini öğrenmeye adanmış bilişim korsanı adaylarıdır.



Bilişim Sistemlerine Yönelik Tehditler

- Zararlı Yazılımlar
- Ağlara Yönelik Tehditler
- Mobil Güvenliğe Yönelik Tehditler
- Bulut Bilişim Ve Tehditler
- Nesnelerin İnterneti Ve Tehditler
- Sosyal Mühendislik

Zararlı Yazılımlar (Malware)

Kötü amaçlı, kötücül yazılım - Malicious Software

Bilişim sistemlerinin işlevlerini bozmak, kritik bilgileri toplamak, zarar vermek gibi kötücül amaçlı kullanılan her türlü zararlı kod, program ve yazılımları tanımlamak için kullanılan genel bir ifadedir.

Zararlı Yazılımlar (Malware)

- Virüsler
- Solucanlar (Worms)
- Truva Atları (Trojans)
- Casus Yazılımlar (Spyware)
- Rootkit (Kök kullanıcı takımı)
- Fidye Yazılımları (Ransomware) (Şantaj)
- Uzaktan Yönetim Aracı (RAT)
- Cryptojacking (Kripto para madenciliği)
- Arka kapı (Backdoor)
- Tarayıcı ele geçirme (Browser hijacking)
- Korunmasızlık sömürücü (Exploit)
- Klavye dinleme sistemi (Keylogger)
- Mesaj sağanağı (spam) (Yığın ileti)



Zararlı Yazılımlar (Malware)

- **Virüsler** (Virus)

Bilişim sisteminin normal çalışmasını, kullanıcının haberi olmadan değiştirmeye çalışan, kendini gizleyen ve bir dosyaya bulaşan, bir bilgisayardan diğerine bulaşmaya çalışan, zararlı kodlar içeren bir bilgisayar programıdır. Bulaştığı dosyanın etkileşime geçmesi, çalışması ile virüs harekete geçer.

- **Solucanlar** (Worms)

Bilişim sisteminde bir dosyaya ilişme ihtiyacı veya insan etkileşimi olmadan kendi başlarına otomatik olarak çalışabilen, başka sistemlere yayılmaya çalışan zararlı kodlar içeren bir bilgisayar programıdır. E-posta, download, reklam vb. yollar ile bilgisayara girebilirler.

- **Truva Atları** (Trojans)

Bilinen bir yazılımın içerisine eklenmiş veya hedeflenen sistemler için yazılmış içerisinde zararlı kodlar barındıran programlardır. Eklendikleri program dosyasının çalışması ile aktif olurlar.

Arka kapı, rootkit, Banking, DdoS, Spy, Psw, proxy, clickers, vb. gibi zararları içerirler.

Zararlı Yazılımlar (Malware)

- **Rootkit**

İşletim sistemi çekirdeğine sızarak saldırgana tam yetki veren zararlı yazılımlardır. Kernel, firmware, application, memory, bootkit, library, hypervisor vmm vb...

- **Ransomware** (Fidye)

Bulaştığı sistem üzerinde dosyaların erişimini şifreleyip engelleyen, dosyaların yeniden kullanımı için fidye talep eden şifreli yazılımlardır. Genellikle kripto para (crypto coin) talep ederler. (WannaCry gibi..)

- **RAT** (Remote Administration Tool - Uzaktan Yönetim Aracı)

Sistemleri uzaktan yönetip teknik destek veya sunucu yönetimi amaçlı faydalı kullanımın kötü amaçlar için yapılmasıdır.

Ağlara Yönelik Tehditler

- Hizmet Dışı Bırakma (DoS) Saldırısı
- Botnetler ve DdoS
- Port Yönlendirme
- Spoofing
- Parola Saldırıları
- ...

Ağlara Yönelik Tehditler

- **DoS** (Denial of Service - Hizmet Dışı Bırakma) Saldırısı

Hedef sistemin kaynaklarını tüketip hizmetlerini geçici veya süresiz olarak aksatarak, görevini yerine getirememesine ve asıl kullanıcılar tarafından ulaşılamamasına neden olan erişilebilirliği hedefleyen bir siber saldırı türüdür.

- **Botnetler** (robot network)

Saldırganlar tarafından trojan veya zararlı yazılımlar ile ele geçirilen ve uzaktan yönetilebilen bilgisayarlardan oluşturulan bir bilgisayar ağıdır. Botnet üyesi bilgisayarlar köle veya zombi olarak ifade edilirler. Botnetler tek bir birim olarak hareket etme yeteneklerine sahiptir. DdoS (Dağıtık DoS) gibi saldırılar için yaygın olarak kullanılırlar.